

端到端加密文件共享系统

在这个项目中,你将使用 Go 语言设计并实现一个安全的文件共享系统。你可以把它想象成类似 Dropbox 的软件,但它使用加密技术来保护你的数据,防止服务器查看或篡改你的数据。

后勤:

团队人数:最多两名学生。

设计文件检查点截止日期: 7 月 22 日星期三晚上 11:59。

实施和修订设计文档截止日期: 7 月 29 日星期三晚上 11:59。

1 项目概述

你将构建一个文件共享系统的客户端。该客户端将允许用户存储和加载文件、与其他用户共享文件,以及撤销其他用户对共享文件的访问权限。

应用程序用户启动客户端后,需要提供用户名和密码。验证通过后,用户即可使用客户端向服务器上传和下载文件。客户端将作为用户与服务器上存储的文件进行交互的界面。

您将在客户端实现 8 个函数: InitUser、GetUser、StoreFile、AppendFile、LoadFile、ShareFile、ReceiveFile 和 RevokeFile。此外,您还需要编写测试来确保客户端的健壮性。我们提供了一些基本功能测试,但您需要自行创建一套完整的测试套件来应对各种攻击。

我们提供 2 台服务器供您使用:

- 第一个服务器 Keystore 为所有人提供公钥存储库。它是可信的。
- 第二台服务器,数据存储区,为所有人提供键值存储。它不受信任。

仅使用这两台服务器和您的计算机安全知识,您将实现上述 8 个功能,以提供一个安全的应用程序。请注意,除了基本的文件共享功能外,您的设计还必须考虑如何确保文件的机密性和完整性。您的客户端也必须是无状态的;如果客户端重启,只需提供用户名和密码,它就必须能够从上次中断的地方继续运行。

2 环境设置

请完成以下四个步骤以开始:

- 安装 Golang ([链接](#))。
- 完成在线 Golang 教程 ([链接](#))。

- 下载骨架代码（§ 2.1）。
- 阅读功能规格说明（第 3 节）。

2.1 框架代码和用户库

框架代码。本项目将使用以下模板：

<https://cs161.org/assets/projects/2/proj2.zip>

所有代码都应该放在 `proj2.go` 和 `proj2_test.go` 文件中：

- `proj2.go`: 您的实现代码写在这里。
- `proj2_test.go`: 你的测试代码放在这里。

用户库。我们在 `userlib.go` 中提供了一些实用函数。要获取此库,请运行：

```
go get -u github.com/cs161-staff/userlib/
```

您可以通过阅读在线文档来熟悉这些功能（包括用户库 API 和各个功能的实现要求）：

<https://cs161.org/assets/projects/2/docs/index>

我们也提供该库的源代码：

<https://github.com/cs161-staff/userlib/>

3. 功能规格

我们提供详细的功能规范,其中详细说明了您必须实现的 8 个客户端功能中每个功能的预期行为。有关您必须实现的功能的详细信息,请参阅以下网站的第 5-6 节（本文档中未包含）：

<https://cs161.org/assets/projects/2/docs/index>

4. 员工建议

· 在开始实施之前,先设计解决方案。学生们一致认为,在多次项目迭代中,设计比实施更难。忠实地实施一个有缺陷的设计并不会获得多少分数。

· 在进行设计时,请阅读功能规格说明,并思考如何实现所需的功能。思考数据存储位置、数据存储在哪台服务器上以及使用何种数据结构可能会有所帮助。

· 如果你遇到困难,可以先考虑如何实现存储/加载功能,暂时不用考虑共享问题。虽然之后你可能需要修改设计以支持安全共享,但如果不涉及共享,这个项目更容易理解。

· 请确保您的实现不会在框架中提供的基本功能测试中出现 panic。如果实现在这些测试中出现 panic,则代码部分将得零分。

- 定期向自动评分系统提交代码。如果你的实现存在问题,自动评分系统会发出警告。
- 在任何隐藏测试中出现恐慌。

5. 威胁模型

我们提供可信的密钥库服务器。该密钥库服务器值得信赖,并且行为可靠。任何攻击者都无法恶意覆盖或篡改存储在密钥库中的密钥记录。

服务器。

我们提供一个不受信任的数据存储服务器。假设攻击者控制了该数据存储服务器和网络。攻击者可以查看、记录、修改和/或添加存储在数据存储服务器中的任何键值对。此外,攻击者还可以观察哪些用户存储了每个键值对,以及键值对的存储、查看或删除顺序。攻击者还可以查看和修改用户之间共享文件时由ShareFile生成的任何access_token。您应该假设攻击者了解系统的设计以及您实现的全部细节。

我们还假设攻击者控制着一个或多个恶意用户。合法用户有可能与恶意用户共享文件。如果发生这种情况,攻击者可以记录有关该文件的所有相关信息(包括任何加密材料和ShareFile生成的任何访问令牌),并记住这些信息,即使之后撤销了对文件的访问权限。

最后,攻击者可以读取公钥库的内容,并利用自动化和暴力破解技术,但会受到实际限制。

6. 澄清事项

- 您可以假设每个用户都有一个唯一的用户名,用户名长度不限,但不能为空。
- 不要假设每个用户都拥有唯一的密码。两个用户可能恰好选择了相同的密码。
 - 密码。
- 您可以假设每个用户的密码通常都是熵的良好来源,但攻击者可能拥有一个预先计算的查找表,其中包含从互联网下载的常用密码的哈希值。
- 不要假设每个文件都有唯一的名称。用户A可以有一个名为foo的文件,但这不应该阻止用户B将其文件之一命名为foo。
 - 文件和文件名可以是任意长度,包括长度为零(空字符串)。
 - 与用户关联的文件数量无需隐藏。
- 攻击者不会发起回滚攻击。但是,恶意数据存储服务器不应该能够欺骗LoadFile函数,使其返回一个新旧数据混合的版本。
- 您无需实现用户间传递access_token的功能。您只需实现ShareFile和ReceiveFile函数,access_token的传递将自动完成。
- 请勿使用密钥库存储除用户公钥/签名密钥以外的任何内容;请勿滥用密钥库存储任何其他信息。具体而言,每个用户

只允许发布固定数量的公钥;用户发布的公钥数量不应取决于存储的文件数量或任何文件的长度、文件已共享的用户数量或系统中已有的用户数量。

7. 一般实施要求

- 不使用全局变量。全局常量可以接受。
 - 在proj2.go中编写的所有函数都必须是无状态的;任何需要永久保存的数据都必须是无状态的。
存储内容应存储在密钥库或数据存储中。
- 如果操作成功,则返回nil作为错误。如果操作失败,则返回除nil以外的值作为错误。
操作失败。
- 如果恶意行为导致函数无法正常运行,则函数必须返回错误。
不要惊慌,不要发生段错误;返回错误。
- 您必须支持给定用户的多个活跃实例。
 - 例如,用户U 可以有二个实例, U1和U2 (一个在笔记本电脑上运行,一个在手机上运行),它们是由使用相同凭据对GetUser()进行两次调用而创建的。
 - 例如:U1 存储文件 F1 后,U2 必须能够 (立即)下载该文件。
 - 例如:U1 追加到 F1 之后,U2 必须能够下载更新后的版本。
 - 例如:U1 通过 ReceiveFile 收到文件 F2 后,U2 必须能够下载该文件。
- 您无需支持并发;假设各个操作都会执行。
依次进行。
- 您的解决方案必须保护ShareFile 生成的所有文件和 access_token 的内容的机密性和完整性。
 - 只有获得授权的用户 即那些已被共享文件且未被撤销授权的用户 才能访问该文件。
能够读取文件内容。
 - 任何违反 IND-CPA 安全性的行为都构成机密性丧失。
- 避免将同一密钥用于多种用途 (例如加密、身份验证、密钥派生等),应先进行身份验证再加密,先解密再验证。这些都是危险的设计模式,往往会导致不易察觉的漏洞。我们会对这些模式进行测试,并将任何此类情况视为违反机密性/完整性的行为。

文件名必须保密。攻击者不应能够猜测任何文件名的长度,甚至无法缩小其长度的可能取值范围。文件内容的长度无需隐藏。

这并非客户端实现中必须保证的所有属性的完整列表。

有关各个功能的具体要求,请参阅文档 (第 3 节) 。

8. 交付成果

8.1 客户端实施

您必须在 proj2.go 中实现以下函数。

- InitUser(username string, password string) (userdataptr *User, err error)
- 获取用户(用户名字符串,密码字符串) (userdataptr *User,err 错误)
- StoreFile(文件名字符串, 数据[]byte)
- LoadFile(filename string) (data []byte, err error)
- AppendFile(filename string, data []byte) (err error)
- ShareFile(filename string, recipient string) (access_token string, err 错误)
- ReceiveFile(filename string, sender string, access_token string) 错误
- RevokeFile(filename string, target_username string) 错误

您可以编写任何结构体或辅助函数来帮助您实现,但您的所有代码都必须包含在 proj2.go 中。

在线文档的相关章节中提供了每个功能必须满足的功能性、效率和安全特性。 ([§ 3](#))

除了模板代码中已列出的库之外,您不得导入任何其他库。

8.2 测试

为你的客户端编写测试。你的测试应该检验客户端的功能是否正确、是否能正确处理错误输入以及是否存在任何安全问题。将你的测试添加到 proj2_test.go 文件中。每个测试都应该放在一个新的函数中。我们提供了几个基本的功能测试作为参考。要测试你的代码,请在终端运行以下命令:

```
go test -v
```

你的考试将会被评分。 ([§ 9](#))

8.3 设计文件

编写一份清晰简洁的实现设计文档。

第一部分:系统设计 [最多 2 页,另加 1 页可选的图表]

总结你的系统设计。解释你做出的主要设计选择,用普通161级学生能够理解的方式撰写,以便他们能够重新实现你的客户端,并取得与你类似的成绩。

作为设计文档的一部分,请以编号列表的形式回答以下关于您设计的问题:

1. 文件在服务器上是如何存储的？
2. 如何与其他用户共享文件？
3. 如何撤销用户对文件的访问权限？
4. 您的设计如何支持高效的文件追加？

第二部分:安全分析 [最多 1 页]

请列举至少三种、至多五种攻击者可能实施的具体攻击,并解释您的设计如何防御每种攻击。每项分析只需一段即可。最终成绩将根据得分最高的三项分析得出。

你必须确保你的攻击:

- 涵盖系统设计的各个方面。也就是说,不要只提供三种攻击方式。
涉及文件存储,但不涉及共享或撤销。
- 请勿包含以下三种类型的攻击:
 - 未加密数据的保密性遭到破坏。
 - 未经认证的数据完整性遭到破坏。
 - 一种导致文件名长度泄露的攻击。

以下是一个更复杂的分析示例:

“用户 A 与用户 B 共享文件后,如果 A 随后撤销了访问权限,用户 B 可能会尝试使用原始访问令牌调用 ReceiveFile 函数来重新获得对该文件访问权限。为了防止已被撤销访问权限的用户以这种方式重新获得访问权限,我们的设计……”

该分析令人满意,因为它描述了可以从提供的威胁模型 (§ 5)和在线文档 (§ 3)中规定的功能描述中得出的具体攻击。

你不得在第二部分报告中讨论此次具体的攻击事件。

你描述的攻击必然会造成安全后果:它不可能是一个简单的漏洞。该攻击必须导致攻击者发现违禁信息或执行未经授权的操作。

9 评分

你将因这个项目获得四个分数。

自动评分代码 [100 pt]

我们将通过一系列功能和安全测试来检验您客户端的实现,以确定您的代码得分。由于计算机安全的特殊性,大多数测试都是隐藏的。

部分检测结果可在截止日期前获得,而其他检测结果则需在截止日期后才能获得。

每次代码测试失败都会对你的分数造成乘法惩罚。这意味着之后每次测试失败对最终成绩的影响都会逐渐减小。这样做是为了模拟一种环境,在这种环境中,漏洞的存在比漏洞的具体范围更为重要。

你的实现至少不能在框架提供的测试用例中出现 panic。如果实现在提供的测试用例中出现 panic,则代码得分不会是 0 分。

自动评分器会针对每次测试运行多个固定的随机种子。由于您的代码必须能够应对各种故障,我们将取多次运行中的最低分作为您代码的最终得分。因此,您的代码引入的任何不确定性都会受到惩罚。

测试覆盖率 [20 分]

我们还会使用您编写的测试用例来测试客户的实际代码实现。我们会检查您的测试覆盖率;客户实际代码实现中的许多行都经过了插桩,因此它们的执行结果将计入您的测试分数。更全面的测试套件将带来更高的覆盖率,从而提高您的分数。您的测试分数将在截止日期前显示在 Gradescope 上。

设计文档评分 [最终稿 20 分,初稿 10 分]

您的设计和安全分析将根据设计文档相关章节 ([§ 8.3](#))中概述的要求,按清晰度和质量进行评分。

设计文档初稿完成后将进行评分,必须在检查点截止日期 (7月22日)前提交。最终设计文档将根据评分标准进行评分,必须在实施截止日期 (7月29日)前提交。

逾期罚款是针对两个截止日期分别计算的。例如,设计文档的逾期提交不会影响按时提交的代码。

9.1 自动评分器规则

禁止任何对抗性行为。您的实现将根据一系列隐藏测试进行自动评分。自动评分器会标记并拒绝任何导入新库或试图执行以下操作的提交:

- 生成其他进程。
- 对文件系统进行读取或写入操作。
- 创建任何网络连接。
- 通过返回冗长的输出来攻击自动评分器。

代码将在隔离的沙箱环境中运行。任何对抗行为都将被视为作弊。

10. 提交内容和交付成果概要

Gradescope 上有三份提交内容,如下所示:

- 实施和测试:提交

proj2.go
proj2_test.go

- 设计文档检查点:提交

设计.pdf

- 修改后的设计文件:提交

设计.pdf